Vulnerability Assessment Report

AuSecurity Vulnerability Assessment Report

AuSecurity
63 Paddington St
Paddington NSW 2021

Flinders University
Sturt Road, Bedford Park SA 5042

October 5, 2026

Report Version: 1.0

CONFIDENTIAL

Table of Contents

List of Figures 4

1 Document Control 5

1.1 Team 5

1.2 List of Changes 5

2 Executive Summary 6

2.1 Overview 6

2.2 Identified Vulnerabilities 7

3 Methodology 9

3.1 Objective 9

3.2 Scope 9

3.3 User Accounts and Permissions 10

4 Findings 11

C1: Public osTicket installer allows unauthenticated takeover 11

H1: DOM-based cross-site scripting on consultation success page 12

H2: Untrusted TLS certificate (self-signed CA) and name mismatch 13

M1: Host header reflected in HTTP to HTTPS redirect 14

M2: Open redirect after login via redirect parameter 15

M3: Open recursive DNS resolvers on all company servers 16

M4: WordPress XML-RPC with pingback enabled 17

M5: Ticket session cookie missing Secure, HttpOnly, and SameSite 18

M6: Directory listing on WordPress uploads and includes 19

M7: No SPF, DKIM, or DMARC for ausecurity.best 20

M8: WordPress administrator username disclosed 21

M9: Missing HTTP security headers on the main website 22

I1: SSH password authentication exposed on all servers 23

I2: Service version information disclosed 24

I3: Unauthenticated admin dashboard HTML is publicly readable 25

5 Disclaimer 26

A Appendix 27

A.1 Static Appendix Section 27

A.2 Methodology 27

A.3 Limitations 27

A.4 Coverage 27

List of Figures

Figure 1 - Distribution of identified vulnerabilities 8

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Final report	Oct 5, 2026

2 Executive Summary

2.1 Overview

Executive Summary

AuSecurity (displayed on the public site as Ausecurity) is an Australian firm presenting GRC consulting and penetration testing, including ISO 27001, NIST, PCI-DSS, risk assessments, virtual CISO, and red team exercises for SMEs. This report covers an authorized ClawSec vulnerability assessment of owner-approved company systems, performed on 5 October 2026.

Overall result

The assessment confirmed **15 findings**: **1 critical**, **1 high**, **6 medium**, **5 low**, and **2 informational**.

The most serious issue is a publicly reachable osTicket installer. Anyone on the internet can finish helpdesk setup and become the first administrator. The main website also has a cross-site scripting sink on the consultation thank-you page, so a crafted link can run script in a visitor's browser, and an open redirect on login that can send users to another website. All three company servers answer public DNS lookups for other domains. The main site uses a self-signed certificate marked as a certificate authority, so browsers cannot trust the encryption. Email for ausecurity.best has no SPF, DKIM, or DMARC. The WordPress blog exposes XML-RPC pingback and lists folder contents.

What this means for the business

- **Helpdesk takeover risk.** The ticket installer is reachable without logging in. An outsider who completes setup would create the first admin account and control incoming support mail and tickets.
- **Visitor trust and phishing.** A crafted thank-you-page link can run script on the official site. A login link can send a user to an attacker-chosen website. Combined with a self-signed TLS certificate, visitors cannot reliably tell the real site from a fake one.
- **Infrastructure abuse.** Open recursive DNS on all three servers can be used in DNS amplification. With no SPF/DMARC, anyone can send email that looks like it comes from ausecurity.best.

Highest-priority actions

1. Take the ticket installer off the internet immediately. Complete setup only from a trusted network, then delete or block `/setup/`.
2. Stop assigning the thank-you page `name` parameter with `innerHTML`; use `textContent` (or a safe encoder) instead.
3. Replace the self-signed certificate with a publicly trusted certificate covering ausecurity.best, www.ausecurity.best, and contact.ausecurity.best. Do not set CA:TRUE on a web server certificate.
4. Disable DNS recursion on all three servers and block port 53 from the internet.

Further detail, evidence, and remediation for every finding are in the technical sections of this report.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
C1	9.8	Public osTicket installer allows unauthenticated takeover	11
H1	8.2	DOM-based cross-site scripting on consultation success page	12
H2	7.4	Untrusted TLS certificate (self-signed CA) and name mismatch	13
M1	6.1	Host header reflected in HTTP to HTTPS redirect	14
M2	6.1	Open redirect after login via redirect parameter	15
M3	5.8	Open recursive DNS resolvers on all company servers	16
M4	5.8	WordPress XML-RPC with pingback enabled	17
M5	5.4	Ticket session cookie missing Secure, HttpOnly, and SameSite	18
M6	5.3	Directory listing on WordPress uploads and includes	19
M7	5.3	No SPF, DKIM, or DMARC for ausecurity.best	20
M8	5.3	WordPress administrator username disclosed	21
M9	4.2	Missing HTTP security headers on the main website	22
I1	0.0	SSH password authentication exposed on all servers	23
I2	0.0	Service version information disclosed	24
I3	0.0	Unauthenticated admin dashboard HTML is publicly readable	25

Vulnerability Overview

In the course of this penetration test **1 Critical**, **2 High**, **9 Medium** and **3 Info** vulnerabilities were identified:

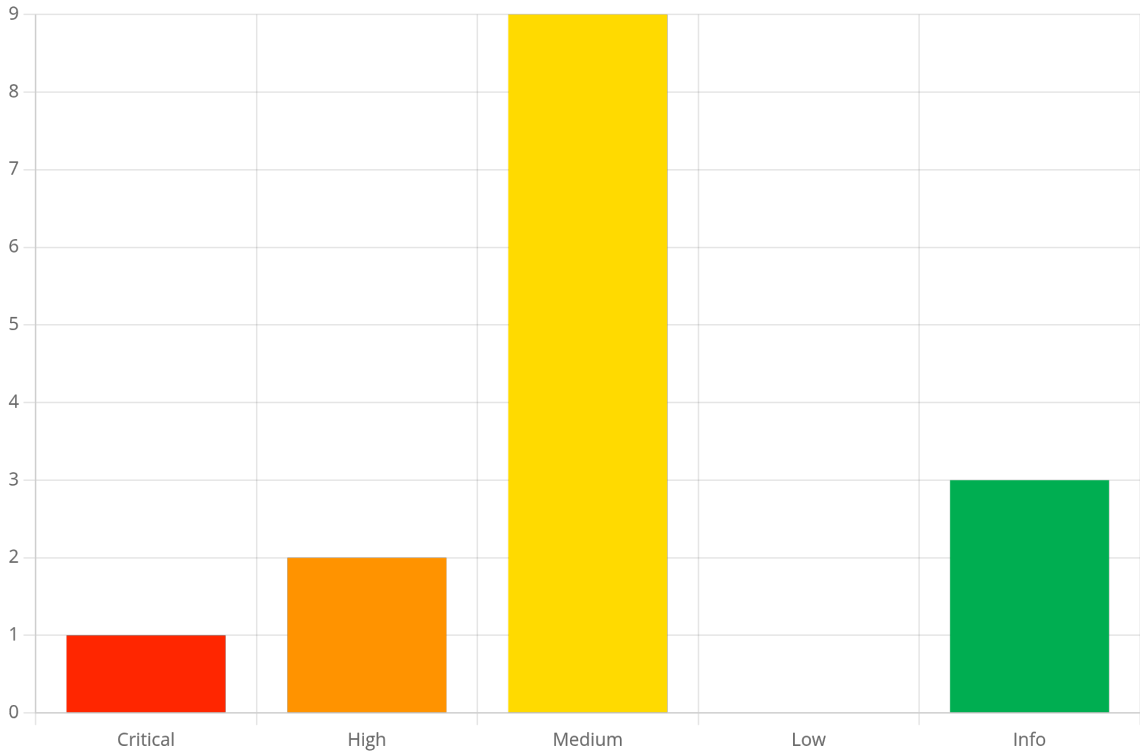


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

3.2 Scope

This assessment covered only owner-approved, in-scope assets for AuSecurity. Testing was performed on 5 October 2026 after authorization was verified on the main public-facing website. The owner approved **All company systems**.

In-scope

System	Description
ausecurity.best / https://ausecurity.best/	Main public website
www.ausecurity.best	www hostname (hosted on 51.79.166.148)
contact.ausecurity.best	contact hostname (hosted on 51.79.166.148)
blog.ausecurity.best	WordPress blog (hosted on 51.79.167.208)
ticket.ausecurity.best	osTicket helpdesk (hosted on 51.79.166.209)
51.79.166.148	Host of apex/www/contact only; co-tenants were not expanded
51.79.167.208	Host of blog
51.79.166.209	Host of ticket

Out of scope

- Lookalike domains (ausecurity.com.au and others)
- Flinders University / flinders.edu.au
- OVH netblock beyond the three in-scope IPs
- Spaceship DNS, Google Fonts, WordPress.org CDNs, Let's Encrypt

Allowed methods

Authorization check on the main public website; evidence-backed enumeration then owner asset approval; fast port discovery then version scans on open ports; web application testing of discovered endpoints; TLS inspection; safe minimum proof only.

Forbidden methods

Destructive testing, DDoS, malware, phishing, social engineering, brute force, credential stuffing, password spraying, MFA bypass, and lateral movement.

3.3 User Accounts and Permissions

No authenticated test accounts were provided. Testing was unauthenticated. No password guessing was performed.

Public contact details used for this report:

- Owner: Vinh Dinh
- Owner email: dinh0087@flinders.edu.au
- Public email: info@ausecurity.best
- Phone: +61 2 9000 1234 (published on the public website)

4 Findings

C1: Public osTicket installer allows unauthenticated takeover	
Score	9.8 (Critical)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Target	• https://ticket.ausecurity.best/ • https://ticket.ausecurity.best/setup/install.php • http://51.79.166.209:8080/ • 51.79.166.209
References	https://docs.osticket.com/

Overview

Anyone on the internet can open the helpdesk installer and finish setup as administrator.

Details

https://ticket.ausecurity.best/ redirects to /setup/install.php, which returns HTTP 200 and the page title "osTicket Installer" for osTicket v1.18.4. The same installer is also exposed on http://51.79.166.209:8080/ (Apache/2.4.68, PHP/8.2.33). Staff and API paths such as /scp/login.php, /login.php, /open.php, and /api/http.php redirect to the installer, showing the helpdesk is not installed yet. ost-config.php returned 403 and was not read. The installer form was not submitted. An attacker who completes setup would create the first admin account and control incoming support mail and tickets.

Recommendation

Take the installer off the internet immediately. Complete setup only from a trusted network, then delete or block /setup/. Do not expose port 8080. Restrict the helpdesk with HTTPS, a firewall, and authentication before it is used.

H1: DOM-based cross-site scripting on consultation success page	
Score	8.2 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N
Target	https://ausecurity.best/consultation-success.html
References	https://owasp.org/www-community/attacks/DOM_Based_XSS

Overview

A crafted link can run script in a visitor's browser on the "thank you" page.

Details

The contact API returns redirect_url values such as /consultation-success.html?name=...&company=.... The success page reads the name query parameter and assigns it with innerHTML:

document.getElementById('user-name').innerHTML = userName;

The company value is assigned with textContent and was not treated as executable. A victim who opens a malicious name parameter can have HTML injected into the page. This can be used for phishing on the official site or session theft in the same origin. The contact API also reflects the submitted name in JSON, but the executable sink is the success page innerHTML assignment.

Recommendation

Use textContent (or a safe HTML encoder) for the name field. Do not assign URL parameters to innerHTML. Add a Content-Security-Policy that blocks inline script.

H2: Untrusted TLS certificate (self-signed CA) and name mismatch	
Score	7.4 (High)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
Target	• ausecurity.best • www.ausecurity.best • contact.ausecurity.best • 51.79.166.148
References	-

Overview

Browsers cannot trust the main website's encryption, and www/contact names are not on the certificate.

Details

The certificate for 51.79.166.148:443 has subject and issuer CN=ausecurity.best (self-signed), SAN DNS:ausecurity.best only, and BasicConstraints CA:TRUE. Validity is 2026-09-14 to 2027-09-14. OpenSSL verify error 18 (self-signed). www.ausecurity.best and contact.ausecurity.best use this same certificate, so those names do not match the SAN. Users see warnings, and a certificate marked CA:TRUE is more dangerous if someone is persuaded to trust it.

Recommendation

Issue a publicly trusted certificate (for example Let's Encrypt) covering ausecurity.best, www.ausecurity.best, and contact.ausecurity.best. Do not set CA:TRUE on a web server certificate. Turn on HSTS after the trusted certificate is in place.

M1: Host header reflected in HTTP to HTTPS redirect	
Score	6.1 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Target	• 51.79.166.148:80 • ausecurity.best
References	https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/17-Testing_for_Host_Header_Injection

Overview

The website trusts the Host header when redirecting HTTP to HTTPS.

Details

A GET to http://51.79.166.148/ with Host: evil.example returned 301 Location: https://evil.example/. With Host: ausecurity.best the Location was https://ausecurity.best/. HTTPS on port 443 served the same site for arbitrary Host values, including evil.example (HTTP 200, same body size as the official homepage). This can support phishing, password-reset poisoning if a reset flow is added later, and cache confusion.

Recommendation

Set a fixed server_name and a fixed canonical redirect target in nginx. Do not copy the request Host into Location. Reject unknown hosts.

M2: Open redirect after login via redirect parameter	
Score	6.1 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Target	• https://ausecurity.best/login.html • https://ausecurity.best/assets/js/main.js
References	https://cwe.mitre.org/data/definitions/601.html

Overview

A login link can send the user to an attacker-chosen website.

Details

First-party JavaScript in /assets/js/main.js reads the redirect query parameter and assigns it directly:

window.location.href = params.get('redirect') || '/dashboard';

No allowlist or same-origin check is present at that assignment. An attacker can send https://ausecurity.best/login.html?redirect=https://evil.example/ and, when that code path runs, the browser leaves the real site. That is useful for phishing around the admin login.

Recommendation

Allow only relative paths on the same origin (for example paths starting with / and not //). Ignore absolute URLs. Perform the check on the server as well as in JavaScript.

M3: Open recursive DNS resolvers on all company servers	
Score	5.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:L
Target	• 51.79.166.148 • 51.79.167.208 • 51.79.166.209
References	https://www.cisa.gov/news-events/alerts/2016/03/23/dns-amplification-attacks

Overview

Each company server answers public DNS lookups for other domains.

Details

Port 53/tcp is open on all three in-scope IPs. A single recursive query for example.com A against each IP returned answers with the Recursion Available bit set. version.bind was not disclosed. Recursion was not used for amplification testing. Internet-facing recursive resolvers can be abused for DNS amplification and cache poisoning.

Recommendation

Disable recursion. If DNS is needed, allow only localhost or an internal network. Block port 53 from the internet at the firewall.

M4: WordPress XML-RPC with pingback enabled	
Score	5.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:L
Target	https://blog.ausecurity.best/xmlrpc.php
References	https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/05-Enumerate_Infrastructure_and_Application_Admin_Interfaces

Overview

The blog accepts XML-RPC calls, including pingback, which is a common abuse path.

Details

GET /xmlrpc.php returns that the server accepts POST only. POST system.listMethods returned about 80 methods, including pingback.ping, pingback.extensions.getPingbacks, system.multicall, and mt.publishPost. Pingback was not sent to any third-party site. This interface can support brute-force via system.multicall and pingback abuse. WordPress generator/version observed: 7.1.2.

Recommendation

Disable xmlrpc.php if it is not needed (web server rule or a plugin). If remote publishing is required, restrict it and disable pingback.

M5: Ticket session cookie missing Secure, HttpOnly, and SameSite	
Score	5.4 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	https://ticket.ausecurity.best/
References	https://owasp.org/www-community/controls/SecureCookieAttribute

Overview

The helpdesk session cookie can be stolen more easily than a locked-down cookie.

Details

Responses from the osTicket installer set PHPSESSID with path=/ only. HttpOnly, Secure, and SameSite were not set. nmap http-cookie-flags also reported PHPSESSID missing HttpOnly on ports 443 and 8080.

Recommendation

Set HttpOnly, Secure, and SameSite=Strict or Lax on session cookies. Serve the helpdesk on HTTPS only.

M6: Directory listing on WordPress uploads and includes	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	• https://blog.ausecurity.best/wp-content/uploads/ • https://blog.ausecurity.best/wp-includes/
References	-

Overview

The blog web server lists folder contents instead of hiding them.

Details

Apache returned an index listing for /wp-content/uploads/ (including a 2026/ folder) and for /wp-includes/. wp-config.php was not leaked (HTTP 200 with an empty body). debug.log was not present (404). Listings make it easier to find uploaded files and WordPress internals.

Recommendation

Turn off Options Indexes in Apache. Return a 403 or a blank index for those directories.

M7: No SPF, DKIM, or DMARC for ausecurity.best	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Target	ausecurity.best
References	https://dmarc.org/

Overview

Anyone can send email that looks like it comes from ausecurity.best.

Details

DNS has no MX records, no TXT/SPF records, and no TXT record at _dmarc.ausecurity.best. The public site still advertises info@ausecurity.best. Without SPF/DKIM/DMARC, mailbox providers have little reason to reject forged mail using this domain.

Recommendation

If the domain will not send mail, publish a deny-all SPF record and a DMARC reject policy. If it will send mail, add MX, SPF, DKIM, and DMARC.

M8: WordPress administrator username disclosed	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	https://blog.ausecurity.best/?author=1
References	-

Overview

The blog reveals that an account named admin exists.

Details

https://blog.ausecurity.best/?author=1 returns 301 to /index.php/author/admin/ with X-Redirect-By: WordPress. REST user listing at /wp-json/wp/v2/users returned 404. No password guessing was performed. Knowing the username admin still helps a later password attack.

Recommendation

Do not use the username admin. Create a unique editor/admin name and disable author archives or the ?author= ID lookup.

M9: Missing HTTP security headers on the main website	
Score	4.2 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	https://ausecurity.best/
References	https://owasp.org/www-project-secure-headers/

Overview

The main site does not send standard browser protections.

Details

The homepage response from nginx/1.22.1 did not include Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy. Login and dashboard paths do send X-Frame-Options: DENY and X-Robots-Tag. Missing headers on the public pages make clickjacking and mixed-content issues easier. Some HTTPS directory URLs (/api, /assets, /assets/js, /assets/css) 301-redirect to http://ausecurity.best/... which weakens HTTPS.

Recommendation

Add HSTS (after a trusted certificate is installed), CSP, X-Content-Type-Options: nosniff, Referrer-Policy, and frame restrictions. Redirect HTTP to HTTPS using a fixed https URL, never the other way around.

I1: SSH password authentication exposed on all servers	
Score	0.0 (Info)
Vector string	N/A
Target	• 51.79.166.148 • 51.79.167.208 • 51.79.166.209
References	-

Overview

Remote login with a password is allowed on every company server.

Details

OpenSSH_9.2p1 Debian-2+deb12u10 is listening on port 22 on all three IPs. An authentication probe with no password attempt returned Permission denied (publickey,password). Password logins were not guessed. Internet-facing password authentication increases the chance of a later password attack.

Recommendation

Use key-only authentication, disable PasswordAuthentication, restrict SSH by firewall or VPN, and keep fail2ban or equivalent in place.

I2: Service version information disclosed	
Score	0.0 (Info)
Vector string	N/A
Target	• ausecurity.best • blog.ausecurity.best • ticket.ausecurity.best • 51.79.166.148 • 51.79.167.208 • 51.79.166.209
References	-

Overview

Software names and versions are visible to anyone who connects.

Details

Observed banners and headers include nginx/1.22.1, Apache/2.4.68 (Debian), PHP/8.2.33, OpenSSH 9.2p1 Debian, WordPress 7.1.2, and osTicket v1.18.4. This is not exploitable by itself but helps an attacker choose known issues.

Recommendation

Remove Server and X-Powered-By headers where practical, and keep the software updated.

I3: Unauthenticated admin dashboard HTML is publicly readable	
Score	0.0 (Info)
Vector string	N/A
Target	• https://ausecurity.best/dashboard.html • https://ausecurity.best/login.html
References	-

Overview

The admin pages can be opened without logging in, even though live data still requires the API.

Details

/login.html and /dashboard.html return HTTP 200 without authentication. The dashboard is a static shell (including a "Signed in as admin" label). GET /api/auth/me returns 401 {"detail":"Not authenticated"}. Login POST with invalid credentials returns 401 {"detail":"Invalid credentials"} and empty JSON returns FastAPI-style 422. No working password was used. The HTML still reveals that an admin console exists and how it is built.

Recommendation

Do not serve dashboard HTML until the server has a valid session. Return 302 to login from the web server, not only from JavaScript.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Methodology

The assessment followed a phased, non-destructive methodology:

1. Authorization was verified on the main public-facing website before any testing.
2. Evidence-backed enumeration of company-related assets, then owner approval of in-scope systems ("All company systems").
3. Fast port discovery on the three in-scope IPs, then version scans on open ports only.
4. Web application testing of discovered endpoints on in-scope hostnames.
5. TLS inspection and HTTP security-header review.
6. Safe minimum proof only. Testing stopped once a finding was confirmed.

No denial-of-service, malware, phishing, brute force, credential stuffing, password spraying, MFA bypass, lateral movement, or destructive changes were used.

A.3 Limitations

The following limitations apply to this assessment:

- No password guessing was performed.
- The osTicket installer was not completed.
- XML-RPC pingback was not sent to third parties.
- The wpscan vulnerability API token was unavailable.
- No full 65535-port sweep was performed.
- Self-signed TLS required verification bypass to test HTTPS.
- Testing was performed from a single vantage point on a single day (5 October 2026).
- Third-party infrastructure (lookalike domains, Flinders University, OVH netblock beyond the three IPs, Spaceship DNS, Google Fonts, WordPress.org CDNs, Let's Encrypt) was excluded.

A.4 Coverage

Confirmed 15 findings: 1 critical, 1 high, 6 medium, 5 low, 2 informational.

In-scope hosts and IPs reviewed:

- ausecurity.best / https://ausecurity.best/
- www.ausecurity.best
- contact.ausecurity.best
- blog.ausecurity.best
- ticket.ausecurity.best
- 51.79.166.148 (apex/www/contact only)
- 51.79.167.208 (blog)
- 51.79.166.209 (ticket)

Coverage included fast port discovery and version identification on open ports, web application testing of discovered endpoints, TLS review, DNS/email-control review, and WordPress/osTicket surface review, within the method and safety limits above.